

Phase A - Theory & Introduction

Amazon S3 Misconfiguration Risks, Encryption, and Access Control

Objective

Understand the security risks created by misconfigured Amazon S3 buckets and how encryption, identity permissions, and resource-based access controls reduce those risks.

Common S3 Misconfigurations and Mitigations

Misconfiguration	Security Risk	Recommended Mitigation
Public read access	Unauthorized users may view or download sensitive objects.	Enable S3 Block Public Access and apply least-privilege policies.
Public write access	Attackers may upload, overwrite, or manipulate bucket content.	Remove public write permissions and restrict writes to approved identities.
Overly permissive policies	Wildcard permissions such as broad s3:* access increase exposure.	Limit actions and resources to what each user, role, or application requires.
Insecure or legacy ACL use	Object-level grants may create unintended access paths.	Prefer IAM and bucket policies; use S3 Object Ownership where appropriate.
Weak encryption controls	Sensitive data may not meet organizational encryption or key-control requirements.	Use default bucket encryption and select SSE-KMS when stronger key governance is required.

SSE-S3 vs. SSE-KMS

SSE-S3: Amazon S3 encrypts objects at rest using keys managed by S3. It is simple to operate because AWS manages the encryption key lifecycle automatically. **SSE-KMS:** S3 uses AWS Key Management Service (KMS) keys. This provides additional control over key permissions, key policies, auditing, and key usage. SSE-KMS is useful when an organization requires stronger governance and visibility over encryption keys.

IAM Roles, Bucket Policies, and ACLs

IAM roles grant permissions to AWS identities or workloads and define which S3 actions they can perform. **Bucket policies** are resource-based JSON policies attached to a bucket and can grant or deny access to the bucket and its objects. **ACLs** are legacy access-control mechanisms that can grant basic permissions at the bucket or object level. Effective S3 security requires evaluating applicable identity- and resource-based permissions together while following least privilege.

Bucket Policy vs. Object ACL

A **bucket policy** centrally controls access to an S3 bucket and selected objects using policy statements, principals, actions, resources, and conditions. An **object ACL** is attached to an individual object and grants a limited set of permissions to specific AWS accounts or predefined groups. For modern S3 environments, bucket policies and IAM policies are generally preferred because they provide more flexible and centralized access control.

Key Security Takeaway

S3 security should combine S3 Block Public Access, least-privilege IAM and bucket policies, appropriate encryption, controlled key access, and regular permission reviews. Avoid unnecessary public access and legacy ACL-based permissions to reduce accidental data exposure.